Podstawy informatyki

Spis treści

Pojęcia 7
Szyfrowanie 7
Algorytmy klasyczne 7
Algorytmy klasyczne – podział 7
Szyfry przestawieniowe 7
Szyfry podstawieniowe 7
Szyfr monoalfabetyczny 7
Szyfr homofoniczny 8
Szyfr wieloalfabetowy 8
Szyfry poligramowe 8
Pięć kryteriów Shannona 8
Szyfry z kluczem 8
Szyfry symetryczne 8
Symetryczne szyfry strumieniowe 9
Symetryczne szyfry blokowe 9
Electronic Code Book 9
Cipher Block Chaining 9
Cipher Feedback 9
Algorytm DES 9
IDEA 9
AES (Rijndael) 10
Blowfish 10
RC5 10
Szyfry asymetryczne 10
RSA 10
Algorytm Diffiego-Hellmana 10
ElGamal 11
Funkcje skrótu 11
MD2 11
MD4 11
MD5 11
SHA-1 12
SHA-2 12
SHA-3 12
Funkcje skrótu – podsumowanie 12
Podpis cyfrowy 13

Niezaprzeczalny podpis cyfrowy 13
Niepodrabialne podpisy cyfrowe 13
Podpis ślepy 13
Podpis symetryczny z arbitrem 13
Podpis symetryczny z arbitrem 14
Public Key Infrastructure (PKI) 14
PKI – niezbędne elementy 14
PKI – funkcje 14
PKI – cykl życia klucza 14
Standard X.509 v3 14
X.509 v3 – certyfikat 14
X.509 v3 – CRL 15
X.509 v3 – certyfikaty atrybutów 15
Proces weryfikowania 15
Przechowywanie certyfikatów 15
CA 15
CA – model hierarchiczny 16
Centra certyfikujące 16
Model OSI-7 16
Warstwa aplikacji 16
Warstwa prezentacji 16
Warstwa sesji 17
Warstwa transportowa 17
Warstwa sieciowa 17
Warstwa łącza danych 17
Warstwa fizyczna 17
Rodzaje ataków 17
Techniki ataków 17
Sniffing 17
Scanning 18
Scanning – nmap 18
Spoofing 18
Poisoning 18
DoS 19
DDoS 19
DRDoS 19
Warstwa sieciowa – zagrożenia 19

Adresacja IP....19
Routing....19
Rozgłoszenia....20
ARP....20
ARP spoofing – przypadek 1....20
ARP spoofing – przypadek 2....20
Warstwa łącza danych – zagrożenia....20
MAC flooding....20
Warstwa transportowa – zagrożenia....20
UDP....20
TCP....21
ARP....21
Jak działa ARP....21
ARP i Windows....21
ARP Poisoning w Windows 7....22
Sesja TCP....22
TCP spoofing....22
SYN flood....23
Ping....23
Ping flood....23
Smurf attack....23
Warstwa aplikacji – zagrożenia....23
DNS....23
Drive-by pharming....24
SMTP....24
E-mail spoofing....24
Backscatter....24
FTP....24
Telnet....24
LDAP....24
Decompression bomb....25
Fork-bomb....25
Brute force....25
Atak słownikowy....25
Rainbow tables....25
Sól....25
SSL/TLS....25

SSL Handshake....26
SSL Change Cipher Specification....26
SSL Alert Protocol....26
SSL Record Layer....26
Nagłówek....26
Utworzenie sesji....26
Utworzenie sesji z uwierzytelnieniem klienta....27
Firewall....27
Firewall – zadania....27
Firewall – rodzaje....27
Firewall....27
Firewall bezstanowy (stateless)....28
Firewall stanowy (stateful)....28
Network-based....28
Host-based....28
Proxy....29
Open Proxy....29
Reverse proxy....29
NAT....29
1 : 1....29
1 : wielu....30
1 : wielu z translacją portów....30
NAT a IPv6....30
DMZ....30
iptables....30
Darmowe Firewalle....31
Konfiguracja firewall....31
VPN....31
VPN – host-to-host....31
VPN – host-to-net (remote-access)....31
VPN – net-to-net (site-to-site)....31
VPN – bezpieczeństwo....32
VPN – szyfrowanie....32
PGP....32
PGP algorytm – szyfrowanie....32
PGP algorytm – deszyfrowanie....32
VPN – tunelowanie....32

VPN – uwierzytelnianie 32
IPSec 33
IPSec – security association 33
Protokół AH 33
Protokół ESP 34
IPSec 34
IPSec – tryb transportowy 34
IPSec – tryb tunelowania 34
NAT Traversal 35
IPSec – bazy danych 35
Baza SPD 35
Baza SAD 35
IPSec – wysyłanie pakietu 36
IPSec – odebranie pakietu 36
IPSec – zarządzanie kluczami 36
IKE 36
IKE – zasada działania 36
Uwierzytelnianie (Kerberos) 36
Kerberos 37
Uwierzytelnianie – algorytm 37

Pojęcia

- Kryptologia – dziedzina wiedzy o przekazywaniu informacji tak, aby uchronić ją przed nieuprawnionym dostępem.
  Dzieli się na:
  - Kryptografię – utajnianie danych
  - Kryptoanalizę – łamanie szyfrów
- Szyfrogram (lub kryptogram) – zaszyfrowana wiadomość
- Klucz szyfrujący – dane służące do szyfrowania
- Klucz deszyfrujący – dane służące do deszyfrowania

Szyfrowanie

- W procesie szyfrowania otrzymujemy szyfrogram
- Procesem odwrotnym jest odszyfrowanie
- Dziedzina przekształceń szyfrujących – zbiór danych, które mogą zostać zaszyfrowane
- Klucz szyfru – parametr decydujący o wyglądzie danych wejściowych

Algorytmy klasyczne

- Używane przed rokiem 1975
- Algorytm musiał być chroniony
- Stosunkowo łatwe do złamania (zwłaszcza w erze komputerów)
- … dla współczesnych metod

Algorytmy klasyczne – podział

- Szyfry przestawieniowe
- Szyfry podstawieniowe
- Szyfry mieszane

Szyfry przestawieniowe

- Polegają na zamianie kolejności znaków
- Zamieniają porządek znaków zgodnie z wybraną figurą geometryczną
- Figura geometryczna oraz sposób zapisu i odczytu stanowią klucz
- Najprostsza metoda – macierz
- Przykład BEZPIECZEŃSTWOSK

B	E	Z	P
I	E	C	Z
E	Ń	S	T
W	O	S	K

Szyfry podstawieniowe

- Monoalfabetyczne
- Homofoniczne
- Wieloalfabetowe
- Poligramowe

Szyfr monoalfabetyczny

- Zamieniają pojedynczy znak teksty jawnego w znak alfabetu szyfrogramu
- Szyfr Cezara → ROT13
- Przykład BEZPIECZEŃSTWOSK

A	Ą	B	C	D	E	Ę	F	G	H	I	J	K	L	Ł	M	N	Ń	O	Ó	P	R	S	Ś	T	U	V	W	Y	Z	Ź	Ż
R	S	Ś	T	U	V	W	Y	Z	Ź	Ż	A	Ą	B	C	D	E	Ę	F	G	H	I	J	K	L	Ł	M	N	Ń	O	Ó	P

BEZPIECZEŃSTWOSK → ŚVOHŻVTOVĘJLNFJĄ

Szyfr homofoniczny

- Każdy znak tekstu jawnego posiada własny zbiór symboli zwanych homofonami
- Liczba homofonów zależy od częstości występowania znaków w tekście jawnym
- Wybór poszczególnych homofonów powinien być losowy
- Pozwoli to uniknąć metodą statystyczną

Szyfr wieloalfabetowy

- Wiele niezależnych podstawień monoalfabetycznych
- Przykład: Tarcza Albertiego
  - Dwie tarcze ze znakami, jedna z tarcz jest obrotowa
  - Osoba deszyfrująca musiała znać znak początkowy i sekwencję obrotów

Szyfry poligramowe

- W jednym kroku szyfrowany jest więcej niż jeden znak
- Przykład: szyfr Playfaira
  - Kluczem szyfru jest macierz kwadratowa
  - Algorytm szyfrowania
  - Wybierz dwa znaki tekstu jawnego
    - Jeśli obydwa znaki są w tym samym wierszu to znaki szyfru odczytujemy z prawej strony znaków tekstu jawnego
    - Jeśli obydwa znaki są w tej samej kolumnie to znaki szyfru odczytujemy poniżej znaków tekstu jawnego
    - Jeśli znaki znajdują się w różnych wierszach i kolumnach to wyznaczany jest prostokąt, którego rogi wyznaczają znaki szyfrogramu
    - Jeśli oba znaki są identyczne wówczas w tekście jawnym wstawiany jest dodatkowy znak
    - W przypadku nieparzystej długości dopisywany jest nieznaczący znak
  - Przykład: alokacja
    - Podziel tekst na bloki dwuznakowe ALOKACJA → AL OK AC JA
    - Zaszyfruj poszczególne bloki

D	W	G	R	C
A	L	O	P	B
E	H	K	S	W
T	M	U	J	N
F	I	Y	Z	X

- AL → OP, OK → UY, AC → BD, JA → TP

Pięć kryteriów Shannona

- Ilość tajności zaoferowanej – wewnętrzna moc algorytmu
- Rozmiar klucza – powinien być możliwie mały
- Łatwość – prostota i jak najmniejsza złożoność procesu szyfracji i deszyfracji
- Propagacja błędów – powinna być zminimalizowana
- Powiększanie się wiadomości – nie jest wskazane

Szyfry z kluczem

- Symetryczne (z tajnym kluczem)
- Asymetryczne (z kluczem publicznym)

Szyfry symetryczne

- Do szyfrowania i deszyfrowania wykorzystywany jest klucz (lub klucze)
- Klucz deszyfrujący można wyznaczyć z klucza szyfrującego i na odwrót

- Klucz nie może zostać ujawniony
- Nadawca i odbiorca muszą znać klucz
- Podział:
    - Algorytmy strumieniowe
    - Algorytmy blokowe

Symetryczne szyfry strumieniowe

- Każdy bit szyfrowany jest osobno
- Do szyfrowania i deszyfrowania wykorzystywany jest ten sam klucz
- Większość systemów opiera się na generatorach ciągów pseudolosowych (klucz)
- Strumień bitów tekstu jawnego jest łączony z kluczem przy użyciu operacji XOR
- Jest szyfrem okresowym gdy strumień klucza się powtarza po pewnej liczbie znaków, w przeciwnym wypadku jest nieokresowy

Symetryczne szyfry blokowe

- Szyfrują bloki wejściowe w oparciu o zdany klucz
- Długość boku wyjściowego jest równa długości bloku wejściowego
- Tryby pracy
    - ECB (Electronic Code Book)
    - CBC (Cipher Block Chaining)
    - CFB (Cipher Feedback)

Electronic Code Book

- Tekst dzielony jest na bloki o ustalonej długości
- Bloki szyfrowane są niezależnie przy użyciu tego samego klucza
- Utrata pojedynczego bloku nie uniemożliwia deszyfracji pozostałych bloków
- Zaleta: szybkość
- Wada: bezpieczeństwo

Cipher Block Chaining

- Każdy blok szyfrogramu zależy zarówno od aktualnie szyfrowanej informacji oraz od wszystkich wcześniejszych
- Wykonywana jest operacja XOR bloku aktualnie szyfrowanego z blokiem szyfrowanym wcześniej

Cipher Feedback

- Wiadomość przesyłana jest znak po znaku
- Wykorzystuje rejestr przesuwny
- Rejestr przesuwny wypełniony jest pewną sekwencją inicjującą
- Aby rozpocząć szyfrowanie musi zostać odebrany cały blok tekstu jawnego

Algorytm DES

- Algorytm symetryczny, blokowy
- Dane o długości 64 bitów
- Klucz 56 bitowy utworzony z 64 bitowego klucza wejściowego
- 8 bitów klucza wejściowego traktuje jako bity parzystości
- Klucz musi być chroniony
- Podatny na ataki typu brute force
- Modyfikacja – 3DES

IDEA

- Algorytm symetryczny, blokowy
- Dane długości 64 bitów

- Klucz długości 128 bitów
- Opiera się na operacjach arytmetycznych takich jak:
    - Suma modulo 2
    - Dodawanie modulo 2^{16}
    - Mnożenie modulo $2^{16} + 1$

AES (Rijndael)
- Algorytm symetryczny, blokowy
- Dane długości 128, 192 lub 256 bitów
- Klucz 128, 192 lub 256 bitów
- Następca DES
- Składa się z kilkunastu iteracyjnie wykonywanych rund
- Liczba rund zależy od rozmiaru klucza
    - 10 dla 128 bitowego
    - 12 dla 192 bitowego
    - 14 dla 256 bitowego

Blowfish
- Algorytm symetryczny, blokowy
- Dane długości 64 bitów
- Klucz od 32 do 448 bitów
- 16 rund

RC5
- Algorytm symetryczny, blokowy
- Dane długości 32, 64 lub 128 bitów
- Klucz od 0 do 2040 bitów
- Od 1 do 255 rund
- Następcą RC5 jest RC6
- RC4 (strumieniowy) nie ma nic wspólnego z RC5

Szyfry asymetryczne
- Wykorzystywane są dwa klucze – tajny i jawny
- Klucz tajny zna tylko właściciel, używany do deszyfracji
- Klucz jawny powszechnie znany, używany do szyfrowania
- Klucza prywatnego nie da się w prosty sposób odtworzyć z klucza publicznego
- Algorytm wykorzystują operacje jednokierunkowe

RSA
- Algorytm asymetryczny
- Wykorzystywany do szyfrowania i podpisów cyfrowych
- Opiera się na faktoryzacji dużych liczba
- Oba klucze (tajny i jawny) są funkcją pary dużych liczb pierwszych
- Klucz prywatny można obliczyć znając liczby pierwsze użyte przy tworzeniu klucza publicznego
- RSA jest wolniejszy niż DES
- W praktyce RSA wykorzystywane jest do wymiany klucza, a szyfrowanie tym kluczem odbywa się przy użyciu algorytmu DES

Algorytm Diffiego-Hellmana
- Służy do ustalenia klucza szyfrującego
- Wymiana może się odbywać niezabezpieczonym kanałem
- Obliczanie logarytmów dyskretnych w ciałach skończonych

- Klucz może posłużyć do szyfrowania komunikacji
- Odporny na podsłuch
- Algorytm nie nadaje się do szyfrowania
- Zasada działania
    - Obie strony wykorzystują generatory g, korzystające z takiego samego zbioru danych
    - Strona A losuje liczbę naturalną a i wysyła stronie B g^a
    - Strona B losuje liczbę naturalną b i wysyła stronie A g^b
    - Strona A oblicza $(g^b)^a$
    - Strona B oblicza $(g^a)^b$

  W ten sposób obie strony posiadają g^{ab} – tajny klucz

ElGamal
- Algorytm asymetryczny
- Umożliwia szyfrowanie oraz obsługę podpisów cyfrowych
- Wykorzystuje algorytm Diffiego-Hellmana
- Opiera się na obliczaniu logarytmów dyskretnych w ciele liczb całkowitych modulo duża liczba pierwsza
- Różne modyfikacje tego algorytmu są bardzo szeroko stosowane

Funkcje skrótu
- Haszujące, mieszające
- Na podstawie porcji danych wyznacza krótki ciąg o stałej długości
- Funkcja jednokierunkowa
- Dla pewnej wiadomości w prosty sposób można utworzyć skrót
- Ze skrótu trudno jest wyznaczyć wiadomość
- Trudno jest znaleźć wiadomość dla której skrót będzie identyczny (kolizja)

MD2
- Stworzona w 1898 roku przez Rona Rivesta
- Losowe permutowanie bajtów
- Wada: szybkość działania
- Nie powinna być wykorzystywana

MD4
- Autor: Ron Rivest
- Skrót o długości 128 bitów
- Blok 512 bitowy (448 + 64 na pierwotną długość), uzupełniany jeśli trzeba (1 i ciąg zer)
- Wynik uzyskiwany jest po przetworzeniu wszystkich bloków
- 4 zmienne łańcuchowe
- Transformacja ma 3 rundy (48 kroków)
- Do wyniku każdego kroku dodawana jest stałą zależna od numeru kroku
- Nie wystarczająco bezpieczna – kolizje występują przy wykonaniu 2^{20} operacji wyznaczania funkcji skrótu

MD5
- Ulepszona wersja MD4
- Skrót o długości 128 bitów
- Zmiany (ulepszenia):
    - Cztery cykle (64 kroki), każdy oparty o inna funkcję nieliniową, 16 operacji w każdym kroku
    - Do wyniku dodawana jest stała zależna od numeru cyklu
    - Zmieniona funkcja w cyklu 2

- Wiadomość pierwotna – konieczność wykonania 2^{64} operacji skracania losowych wiadomości

SHA-1

- Zaprojektowany przez NIST i NSA
- Blok 512 bitów (448 + 64), uzupełnienie jak w MD5
- Skrót 160 bitów
- Bazuje na MD4
- 5 32 bitowych zmiennych łańcuchowych
- 4 cykle, każdy po 20 operacji
- Konwersja wejściowego ciągu: Big-endian
- Niebezpieczny

SHA-2

- SHA-224, SHA-256, SHA-384, SHA-512 – długość skrótu
- Maksymalny rozmiar wiadomości: $2^{64} – 1$ (SHA-224, SHA-256), $2^{128} – 1$ (SHA-384, SHA-512)
- Blok 512 bitów SHA-224, SHA-256 (16x32 bity), 1024 bitów SHA-384, SHA – 512 (16x64 bity)
- 64 rundy SHA-224, SHA-256, 80 rund SHA-384, SHA-512

SHA-3

- Algorytm Keccak
- W 2012 roku wygrał konkurs na funkcję haszującą (NIST)
- Wyższa wydajność niż SHA-2
- Jest alternatywą dla innych funkcji haszujących
- 24 rundy x 5 funkcji
- Konstrukcja gąbki

Funkcje skrótu – podsumowanie

Funkcja		**Długość skrótu [b]**	**Blok [b]**	**Max wielkość wiadomości**	**Kroki**	**Operacje**
MD4		128	512	2^{64} - 1	48	and, or, xor, not
MD5		128	512	$2^{64} – 1$	64	and, or, xor, not
SHA-1		160	512	$2^{64} – 1$	80	and, or, xor, not
SHA-2	SHA -224	224	512	$2^{64} – 1$	64	and, or, xor, shr, rot
	SHA-256	256				
	SHA-384	384	512	2^{128} - 1	80	
	SHA-512	512				
SHA-3		224 256 384 512	1152 10880 832 576		24	and, xor, not, rot

Podpis cyfrowy

- Służy do zagwarantowania
  - Autentyczności
  - Niezaprzeczalności
  - Integralności
- Kombinacja kryptografii asymetrycznej i jednokierunkowej funkcji skrótu
- Jest funkcją podpisywanej wiadomości i pewnej informacji znanej autorowi (klucz prywatny)
- Może zostać zweryfikowany przy użyciu klucza publicznego
- Pojęcia
  - Podpis odręczny
  - Podpis elektroniczny
  - Zaawansowany podpis elektroniczny
  - Kwalifikowany podpis elektroniczny
- Ustawa z dnia 18.09.2001 – podpis elektroniczny jest prawnie równoważny z podpisem odręcznym

Niezaprzeczalny podpis cyfrowy

- Nadawca nie może wyprzeć się wiadomości
- Nadawca musi zgodzić się na weryfikację podpisu
- Algorytm
  - Nadawca wysyła odbiorcy dokument wraz z podpisem
  - Odbiorca generuje losową liczbę i przesyła ją nadawcy
  - Nadawca przy użyciu klucza prywatnego przekształca liczbę
  - Nadawca przesyła wynik odbiorcy
  - Odbiorca weryfikuje podpis

Niepodrabialne podpisy cyfrowe

- Pozwala wykryć fałszerstwo
- Dla klucza publicznego istnieje wiele kluczy prywatnych
- Ciężko jest znaleźć właściwy klucz prywatny
- Dokument podpisany z wykorzystaniem podrobionego klucza prywatnego – inny podpis
- Oznacza to, że można w prosty sposób wykryć próbę podrobienia wiadomości

Podpis ślepy

- Podpisujący nie powinien poznać treści dokumentu
- Przykład: osoba podpisująca ma potwierdzić dostarczenie wiadomości, a nie jej treść
- Wykorzystanie czynnika zaciemniającego
- Problem: skąd osoba podpisująca wie co podpisuje?

Podpis symetryczny z arbitrem

- W transmisji uczestniczy osoba będąca arbitrem – zaufana osoba, która poświadczy wiadomość
- Arbiter dzieli klucz Kn z nadawcą i klucz Ko z odbiorcą
- Algorytm
  - Nadawca szyfruje wiadomość dla odbiorcy i przesyła do arbitra
  - Arbiter odszyfrowuje wiadomość, używając klucz Kn
  - Arbiter łączy odszyfrowaną wiadomość z zaszyfrowaną od nadawcy. Całość szyfruje kluczem Ko
  - Odbiorca deszyfruje wiadomość przy użyciu klucza Ko. Otrzymuje w ten sposób wiadomość i poświadczenie źródła wiadomości od arbitra.

Podpis symetryczny z arbitrem

- Podpis jest niepodrabialny
- Podpis jest autentyczny
- Wygenerowany dokument jest niezmienialny
- Niezaprzeczalność

Public Key Infrastructure (PKI)

- Służy do zarządzania kluczami publicznymi użytkowników
- Pozwala wiązać klucz publiczny z daną osobą
- Właściciel tworzy parę kluczy, skrót klucza publicznego jest certyfikowany
- PKI służy do zapobiegania fałszerstwom polegającym na podmianie klucza

PKI – niezbędne elementy

- Centra certyfikacji (CA)
- Urzędy rejestrujące (RA)
- Posiadacze certyfikatów
- Klienci
- Repozytoria

PKI – funkcje

- Wystawianie certyfikatów
- Weryfikacja certyfikatów
- Weryfikacja tożsamości
- Potwierdzenie tożsamości
- Znakowanie czasem
- Szyfrowanie i podpisywanie przekazu

PKI – cykl życia klucza

- Utworzenie
- Certyfikacja
- Rozprowadzenie
- Użytkowanie aktywne
- Użytkowanie pasywne
- Unieważnienie klucza

Standard X.509 v3

- Najpopularniejszy standard certyfikatów PKI
- Definiuje schemat certyfikatu, unieważnień (CRL) i atrybutu
- Nadzorowany przez ITU-T
- Pierwsza wersja standardu została opublikowana w 1988 roku

X.509 v3 – certyfikat

- Certyfikat składa się z:
  - Wersji
    - Numeru seryjnego
    - Sygnatury
    - Informacji o wystawcy
    - Identyfikatora algorytmu
    - Daty ważności
    - Informacji o właścicielu
    - Klucza publicznego właściciela
    - Rozszerzenia

X.509 v3 – CRL

- Certificate Revocation List
- Lista unieważnionych certyfikatów
- Publikowana przez CA
- Zawiera wyłącznie numery seryjne unieważnionych certyfikatów
- Posiadacz klucza zwraca się do CA w celu unieważnienia certyfikatu

X.509 v3 – certyfikaty atrybutów

- Atrybuty opisujące uprawnienia
- Rozdzielenie autoryzacji od uwierzytelniania

Proces weryfikowania

- Użytkownik zgłasza się do CA ze swoim kluczem publicznym
- Do weryfikacji wykorzystywany jest klucz publiczny CA

Przechowywanie certyfikatów

- Serwery LDAP
- Serwery WWW
- Serwery FTP
- Serwery DNS
- X.500
- Bazy danych
- OSCP

CA

- Wewnętrzna

  \+ prostsze zarządzanie

  \+ brak kosztów certyfikatów

  \+ tańsza rozbudowa systemu

  \- bardziej skomplikowana implementacja

  \- kwestie bezpieczeństwa spoczywają na właścicielu

  \- brak zaufania

- Zewnętrzna

  \+ bezpieczeństwo i odpowiedzialność spoczywają na CA

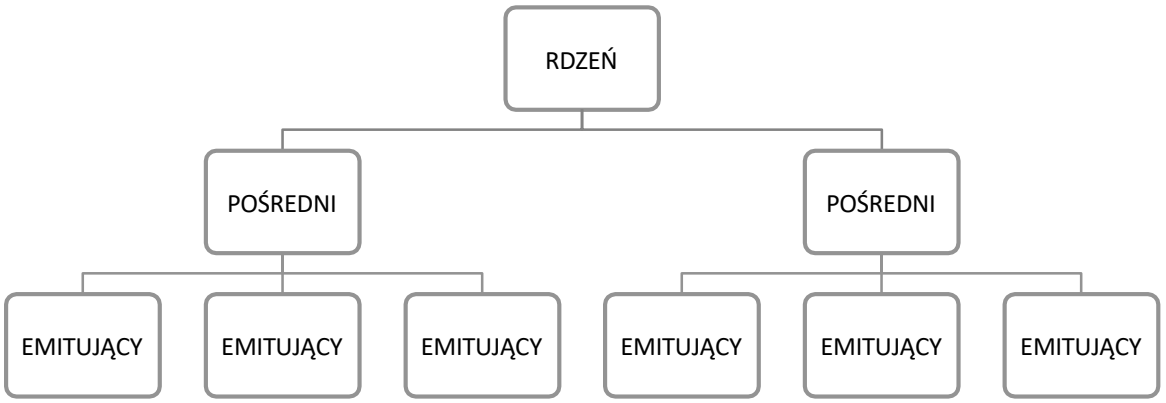
  \+ zaufanie

  \- konieczność płacenia za każdy certyfikat

  \- mniejsza elastyczność w przypadku konfiguracji i zarządzania

  \- skomplikowana integracja

CA – model hierarchiczny



Poziom emitujących powinien być weryfikowany przez nasz poziom pośredni.

Emitujący to osoba/firma, która wystawia konkretny certyfikat dla klienta.

Centra certyfikujące

- Komercyjne:
  - Symantec
  - Comodo Group
  - Go Daddy
  - GlobalSign
- Komercyjne PL:
  - KIR (Szafir)
  - PWPW (Sigillium)
  - Unizeto Technologies
- Niekomercyjne
- OpenCA
- OpenSSL
- TinyCA

Model OSI-7

Warstwa aplikacji

Warstwa prezentacji

Warstwa sesji

Warstwa transportowa

Warstwa sieciowa

Warstwa łącza danych

Warstwa fizyczna

Warstwa aplikacji

- Protokoły: FTP, TFTP, DNS, SMTP, SIP, HTPP, SNMP, RTP, Telnet, DHCP
- Definiuje interfejs transmisji danych przez aplikacje

Warstwa prezentacji

- MPED, JPG, TIFF, GIF
- Odpowiada za szyfrowanie, kodowanie, kompresję oraz konwersję danych

Warstwa sesji

- Protokoły: L2TP, PPTP, NetBIOS
- Odpowiada za negocjację i nawiązywanie połączenia

Warstwa transportowa

- Protokoły: TCP, UDP, SPX
- Odpowiada za przekazywanie danych między urządzeniami
- Dane dzielone są na części
- Port

Warstwa sieciowa

- Protokoły: IP, ICMP, ARP, RARP, IPsec
- Odpowiada za trasowanie pakietów
- Zna topologię sieci
- Adres logiczny

Warstwa łącza danych

- Protokoły: PPP, ATM, HDLC, ARP, X.25, Ethernet
- Nadzoruje błędy w warstwie fizycznej
- Enkapsulacja w ramki
- Adres fizyczny

Warstwa fizyczna

- Protokoły: Ethernet, RS-232, RS-459, DSL, PDF, Bluetooth
- Obsługa fizycznego wysyłania i odbierania sygnałów
- Sygnały elektryczne, radiowe i optyczne
- Przesył danych binarnych
- Brak mechanizmów kontroli

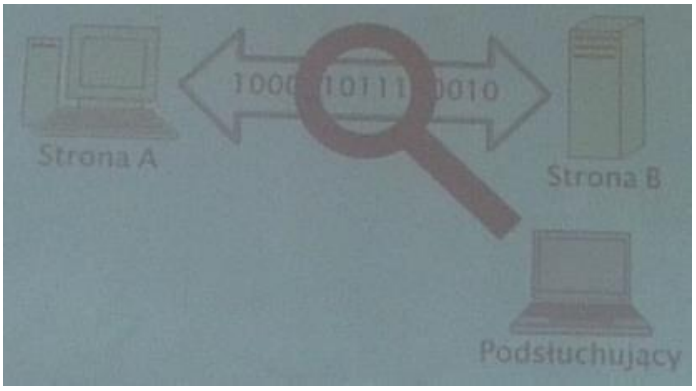
Rodzaje ataków

- Pasywne
- Aktywne

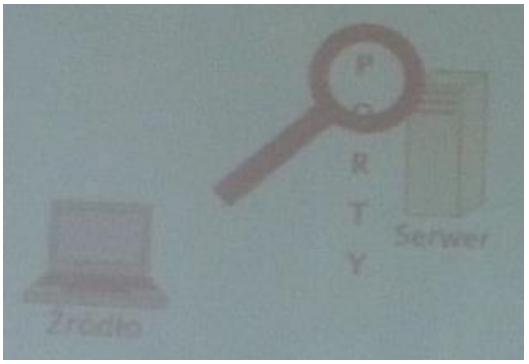
Techniki ataków

- Sniffing
- Scanning
- Spoofing
- Poisoning
- Denial Of Service / Distributed Denial Of Service

Sniffing



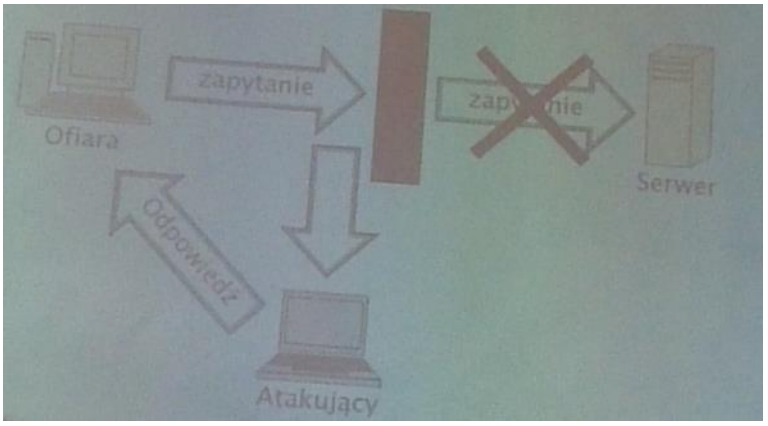
Scanning



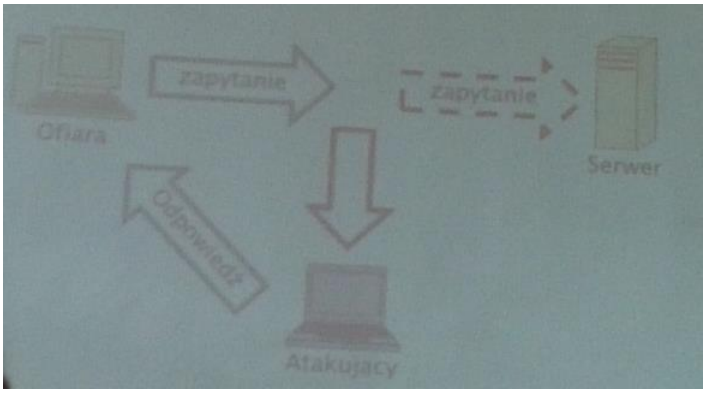
Scanning – nmap

- Skanowanie
  - TCP (nmap – sT)
  - UDP (nmap – sU)
  - SYN (nmap – sS)
  - ACK (nmap – sA)
  - FIN (nmap – sF)
  - Ping (nmap – sP)

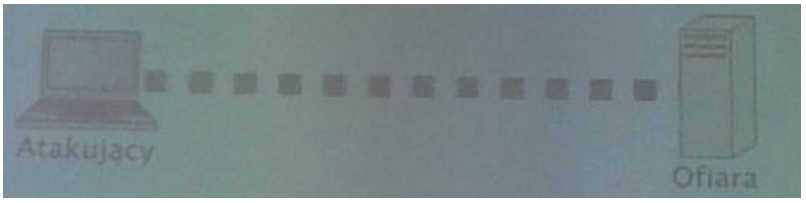
Spoofing



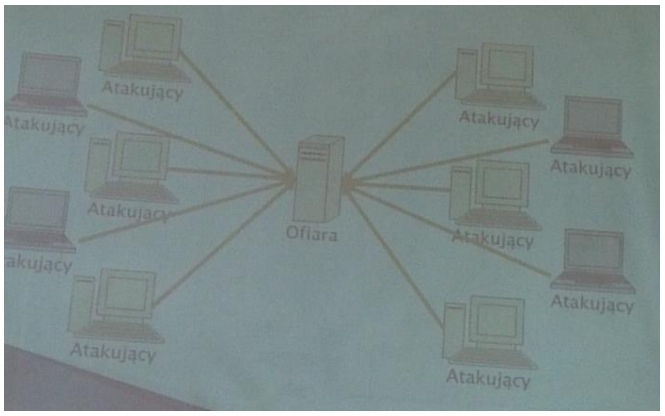
Poisoning



DoS

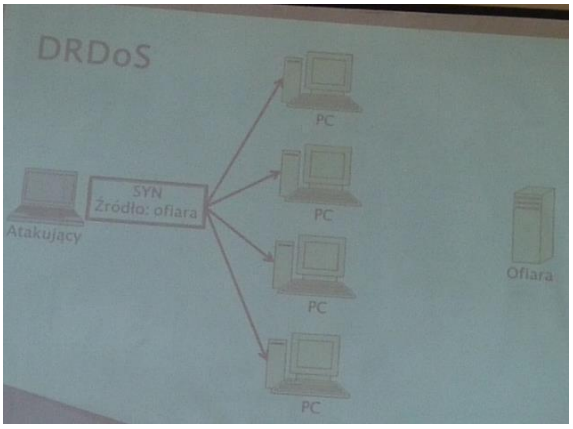


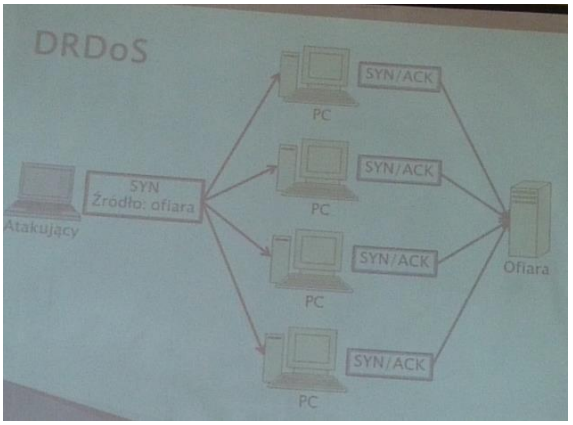
DDoS



DRDoS







Warstwa sieciowa – zagrożenia

Adresacja IP

- Możliwość modyfikacji adresu źródłowego
- IP spoofing

Routing

- Przekazywanie pakietów w oparciu o zdefiniowane reguły (tablice routingu)
- Za trasowanie odpowiedzialny jest router
- Router w przypadku przeciążenia odrzuca pakiety
- Retransmisja zależy od protokołu warstwy wyższej

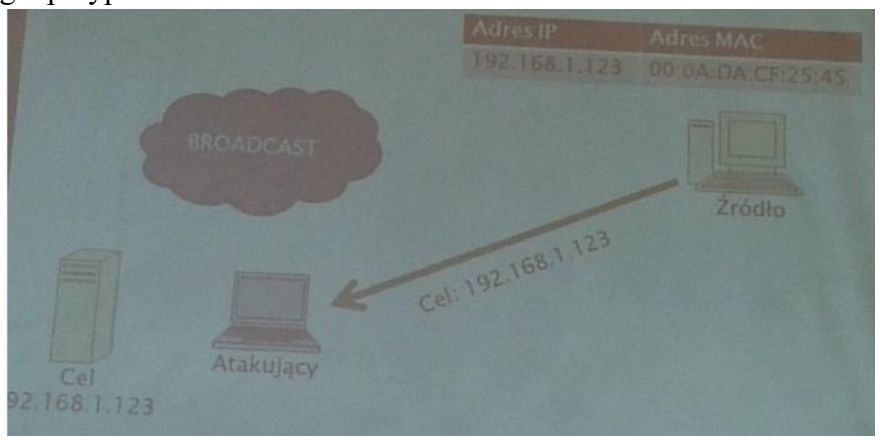
Rozgłoszenia

- W każdej sieci IP występuje adres broadcast
- Wysłanie pakietu na taki adres spowoduje rozesłanie go do wszystkich urządzeń w sieci
- Również w warstwie łącza danych istnieje adres broadcast

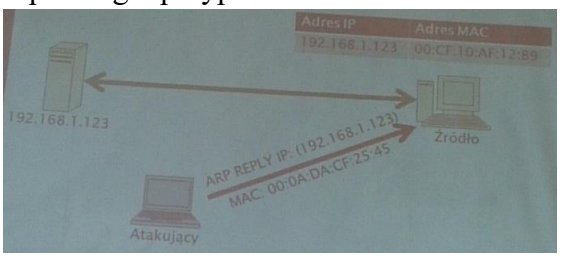
ARP

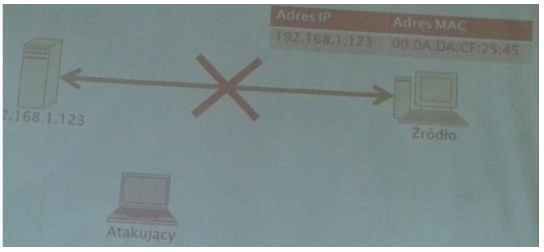
- Umożliwia mapowanie adresów logicznych na fizyczne
- Opisuje sposób utrzymania tablic ARP
- Zagrożenia
    - ARP spoofing

ARP spoofing – przypadek 1



ARP spoofing – przypadek 2





Warstwa łącza danych – zagrożenia

MAC flooding

- Tablica CAM przełącznika przechowuje adresy MAC i skojarzone z nimi porty
- Atak polega na wysłanie wielu pakietów z różnymi adresami źródłowymi MAC
- Przełącznik stara się przypisać źródłowe MAC do portu
- W momencie przepełnienia tablicy CAM przełącznik zaczyna działać jak koncentrator
- Atakujący uzyskuje w ten sposób dostęp do wszystkich pakietów przekazywanych w sieci

Warstwa transportowa – zagrożenia

- UDP
- TCP

UDP

- User Datagram Protocol
- Protokół bezpołączeniowy
- Brak kontroli przepływu
- Zaletą jest szybkość działania (brak narzutów)

- Wykorzystywany wszędzie tam gdzie ważna jest szybkość działania, a nie koniecznie dokładność
- Zagrożenia
    - UDP spoofing
    - UDP flood
    - DoS

TCP

- Transmission Control Protocol
- Połączeniowy i niezawodny protokół komunikacyjny
- Kontrola przepływu i retransmisja
- Wolniejszy od UDP
- Wykorzystywany wszędzie tam gdzie ważna jest dokładność, a nie szybkość

ARP

Jak działa ARP

1. W momencie gdy urządzenie źródłowe chce rozpocząć komunikację z innym urządzeniem w pierwszej kolejności sprawdza pamięć podręczną ARP pod katem docelowego adresu MAC. Gdy wpis zostanie znaleziony następuje transmisja.
2. Gdy wpis nie zostanie znaleziony, źródło wygeneruje ARP request. ARP request zawiera adres IP i MAC źródła oraz IP celu. Mac celu jest pusty.
3. ARP request zostaje wysłany jako rozgłoszenie do wszystkich urządzeń w sieci.
4. Każde urządzenie odbiera pakiet i porównuje docelowy adres IP ze swoim adresem. Jeśli adresy się nie zgadzają pakiet zostanie odrzucony.
5. Gdy adresy się zgadzają to urządzenie generuje ARP reply. Celem jest adres źródła (IP i MAC) z ARP request.
6. Aby wysłać ARP reply urządzenie dodaje do swojej pamięci podręcznej ARP odpowiedni wpis (cel transmisji). Odpowiedź wysyłana jest bezpośrednio do źródła ARP request (unicast).
7. Źródło przetworzy pakiet i doda do swojej pamięci podręcznej odpowiedni wpis.

ARP i Windows

- Opis dotyczy systemów od Windows Vista
- Jeśli wpis w tablicy ARP ma status **Reachable** to transmisja odbywa się zgodnie z tym wpisem
- Jeśli wpis nie jest używany przez określony czas to zmienia status na **Stale**
- Jeśli wpis w tablicy ma status **Stale** wówczas system musi wysyłać nowy pakiet ARP request aby odświeżyć wpis
- Czas osiągalności określony jest wzorem:

$$BaseReachable * losowa\ wartość\ z\ przedziału(MIN, MAX)$$

$BaseReachable$: 30 000 $[ms]$
MIN: 0,5
MAX: 1,5
Oznacza to, że jeśli wpis nie jest używany przez 15-45 sekund zostanie ustawiony status **Stale**.

- Sprawdzenie aktualnego czasu osiągalności dla interfejsu:
    - **netsh interface ipv4 show interfaces** – wyświetlona zostaje lista dostępnych interfejsów
    - **netsh interface ipv4 show interface INDEX** – informacja na temat czasu osiągalności
    - **netsh interface ipv4 set interface INDEX basereachable=CZAS[ms]** – zmiana referencyjnego czasu osiągalności
- Domyślny rozmiar pamięci podręcznej: 256
- Aby zmienić rozmiar należy skorzystać z polecenia: **netsh interface ipv4 set global neighborcachelimit = 4096**

- Wyświetlenie tablicy arp: **arp –a**
- Dodanie statycznego wpisu: **arp –s IP MAC**
  Tak dodane wpisy są ważne tylko do ponownego uruchomienia komputera.
- Dodanie wpisu na stałe:

  C:\Windows\system32\drivers\etc\hosts

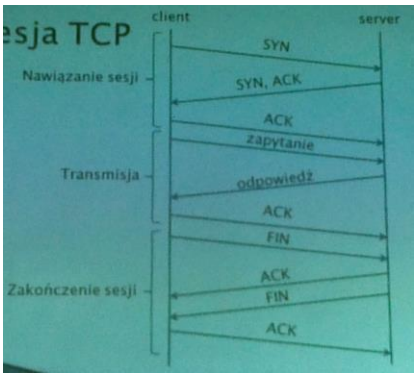
  Należy dodać odpowiedni wpis do pliku hosts.

- Usunięcie pojedynczego wpisu: **arp –d IP**
- Usunięcie wszystkich wpisów: **arp –d *** lub **netsh interface ip delete arpcache**

ARP Poisoning w Windows 7

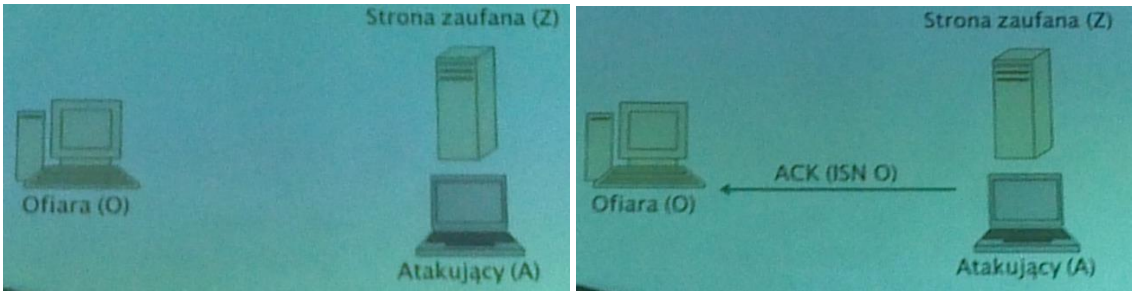
- Wysłanie ARP Reply do urządzenia z Windows 7 nie spowoduje zmiany w tablicy. Firewall w Windows zablokuje taki pakiet.
- W momencie gdy ofiara wykryła i zignorowała ARP reply nastąpi wysłanie pakietu ARP Request. Docelowym adresem IP będzie adres źródłowy otrzymanego ARP Reply. ARP Request zostanie wysłany w formie unicast. Następnie system nie otrzyma odpowiedzi i wyśle ARP Request w formie rozgłoszenia. Uzyskana odpowiedź będzie potwierdzeniem prawidłowości wpisu.
- **Co jeżeli atakujący odpowie na pytanie systemu?**
- Wysłanie pakietu ARP request ze sfałszowanym adresem źródłowym i prawidłowym docelowym IP spowoduje dodanie wpisu do tablicy ARP ofiary.
- Komputer ofiary odpowie ARP reply.
- Następnie ofiara wyśle pakiet ARP request pytając o adres źródła dla którego utworzony został wpis.
- Gdy atakujący nie odpowie, ofiara wyśle ARP request w formie rozgłoszenia. Uzyskana odpowiedź spowoduje zmianę wpisu w tablicy ARP.
- **Co jeżeli wpis już istnieje?**

Sesja TCP

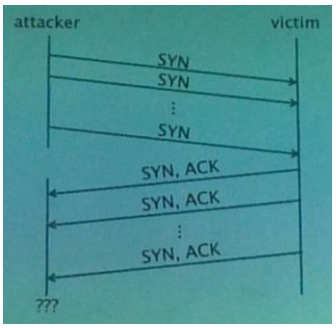


TCP spoofing

- Celem jest zestawienie połączenia z ofiarą ataku podszywając się pod zaufany system
- Wymaga sfałszowania adresu źródłowego i znalezienia prawidłowego ISN



SYN flood



Ping

- Program do diagnozowania połączeń sieciowych
- Podaje liczbę zagubionych pakietów oraz opóźnienie transmisji
- Wykorzystuje protokół ICMP (ICMP Echo Request i ICMP Echo Reply)

Ping flood

- Duża liczba pakietów ICMP
- Ma za zadanie przeciążyć łącze ofiary
- Atakujący musi posiadać łącze o wyższej przepustowości niż ofiara
- Atak może zostać przeprowadzony z wielu maszyn równocześnie

Smurf attack

- Następca Ping flood
- Atakujący nie musi posiadać wyższej przepustowości łącza niż ofiara
- ICMP Echo Request wysyłane jest ze zmienionym adresem źródłowym – adres ofiary
- Pakiety wysyłane są na adres rozgłoszeniowy dużej sieci
- Komputery, które odebrały pakiety wysyłają ICMP Echo Reply na adres ofiary

Warstwa aplikacji – zagrożenia

DNS

- Domain Name System
- Służy do zamiany nazw domenowych zrozumiałych dla użytkownika na adresy zrozumiałe dla urządzeń sieciowych
- Struktura hierarchiczna
- Rozproszona baza danych
- Zagrożenia:
  - DNS korzysta z protokołu UDP – DdoS
  - Brak mechanizmów autoryzacji – Man in the middle
  - Zatruwanie pamięci cache – cache poisoning
- DNSSec

Drive-by pharming

- Ma za zadanie podmianę serwerów DNS na routerze ofiary
- Konsekwencją jest to, że użytkownik może zostać skierowany na spreparowane strony internetowe
- Główna przyczyna opiera się na zbyt słabym haśle routera

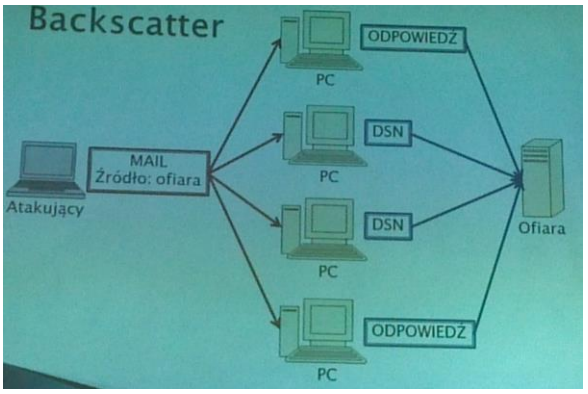
SMTP

- Simple Mail Transfer Protocol
- Przekazywanie poczty elektronicznej
- Brak weryfikacji nadawcy
- Zagrożenia
    - Sniffing
    - Spoofing
    - Phishing
    - Man in the middle
- SMTP-AUTH
- TLS/SSL

E-mail spoofing

- E-mail ze sfałszowanym nagłówkiem
- Umożliwia to podszycie się pod np. zaufane źródło

Backscatter



FTP

- File Transfer Protocol
- Transfer plików
- Zagrożenia:
    - Błędne uprawnienia
    - DoS
- FTPS

Telnet

- Obsługa terminala w architekturze klient-serwer
- Połączenie nie jest szyfrowane
- Zagrożenia:
    - Spoofing
    - Sniffing
- SSH

LDAP

- Lightweight Directory Access Protocol

- Bazuje na standardzie X.500
- Protokół usług katalogowych
- Wykorzystuje TCP/IP
- Nie jest szyfrowany
- Zagrożenia
    - Man in the middle
    - Sniffing

Decompression bomb

- Archiwum (np. zip), które może spowodować
    - Wygenerowanie nieskończenie dużego pliku
    - Wygenerowanie bardzo dużego pliku (poprzez wysoki stopień kompresji)
- Łatwy do wykrycia przez oprogramowanie antywirusowe

Fork-bomb

- Polega na utworzeniu wielu kopii programu w celu wypełnienia tablicy procesów
- Nie ma możliwości wywołania nowego procesu
- Zabezpieczenie: limit procesów, które mogą zostać utworzone przez użytkownika

Brute force

- Może zostać wykorzystany w ataku na dowolny system kryptograficzny
- Systematyczne sprawdzanie wszystkich możliwych kombinacji (kluczy, haseł)
- Dla krótkich haseł metoda działa dość szybko
- Przy dłuższych hasłach czas szukania jest nieakceptowalny
- Zasoby

Atak słownikowy

- Metoda zbliżona do brute force
- Wykorzystywany jest słownik, który może być np. listą słów najczęściej występujących w danym języku

Rainbow tables

- Baza zwierająca skróty
- Wykorzystywane w łamaniu haseł zakodowanych jednokierunkową funkcją skrótu
- Baza tworzona jest przez zapisywanie łańcuchów ze skrótów z haseł
- Mniej mocy obliczeniowej niż BruteForce

Sól

- Pozwala zabezpieczyć się przed próbami złamania hasła
- Sól to losowo generowana wartość dodawana do skrótu

SSL/TLS

- Zapewnia poufność, integralność i uwierzytelnianie
- 1994 – pierwsza wersja protokołu SSL (Netscape)
- 1995 – SSL 3
- W 1996 grupa TLS zaczęła pracę nad rozwinięciem SSL
- Klucze 40 bitowe nie zapewniały bezpieczeństwa
- Obecnie min. 128 bitowe klucze
- Działa w warstwie prezentacji
- Wykorzystywany m.in. przez: HTTPS, POP3, IMAP, STMP, FTPS
- Wykorzystuje symetryczne i asymetryczne algorytmy szyfrowania
- Podprotokoły
    - SSL Handshake

- SSL Change Cipher Specification
- SSL Alert Protocol
- SSL Record Layer

SSL Handshake

- Służy do zabezpieczenia:
  - Uwierzytelniania serwera
  - Uwierzytelniania klienta (nieobowiązkowe)
  - Wymianę informacji niezbędnych do wyliczenia wspólnego sekretu
- Dwa rodzaje komunikatów:
  - Nawiązanie nowej sesji
  - Odnowienie sesji

SSL Change Cipher Specification

- Jeden komunikat
- Sygnalizacja, że zmienione zostały parametry zabezpieczenia
- Zmiana przeprowadzona jest niezależnie (klient i serwer)

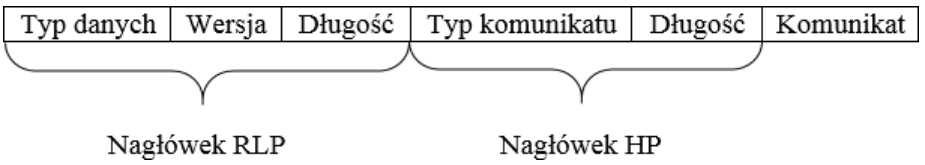
SSL Alert Protocol

- Informuje o błędach w komunikacji
- Dwa poziomy ważności:
  - Warning – komunikacja może przebiegać dalej
  - Ciritical error – komunikacja zostaje zakończona

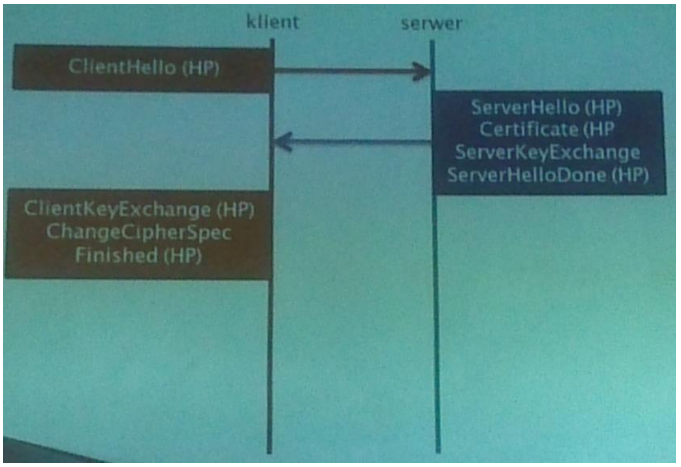
SSL Record Layer

- Dzieli dane na fragmenty mniejsze niż 2^{14}B
- Przeprowadza kompresję danych (o ile obie strony się zgodziły)
- Oblicza sumę kontrolną
- Uzupełnia blok, gdy dane zajmują mniej niż przewiduje blok szyfru

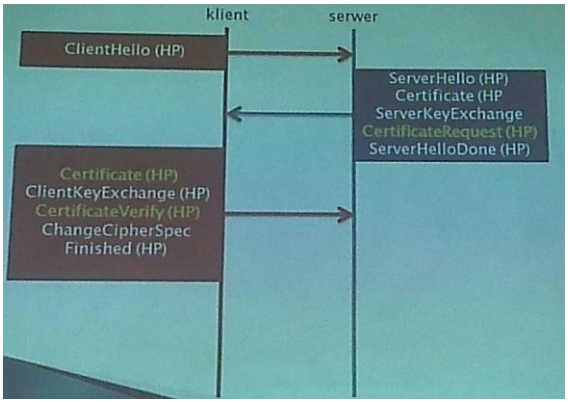
Nagłówek

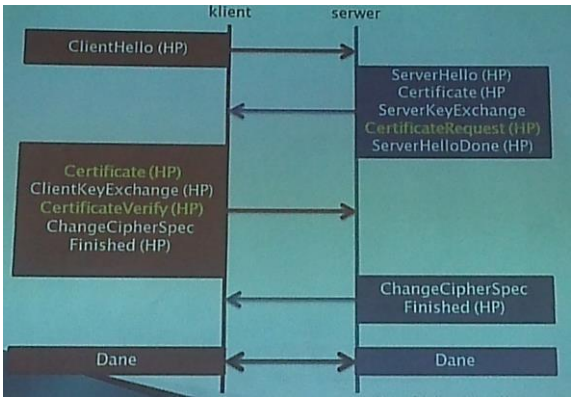


Utworzenie sesji



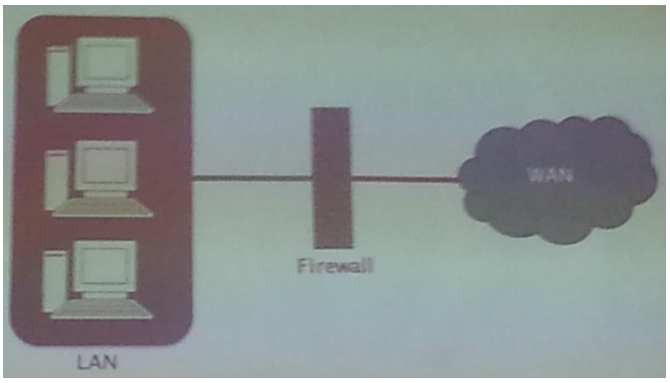
Utworzenie sesji z uwierzytelnieniem klienta





Firewall

- System bezpieczeństwa służący do kontroli ruchu przychodzącego i wychodzącego
- Działa w oparciu o reguły
- Pakiety filtrowane są pod katem spełniania reguł
- Znajduje się pomiędzy bezpieczną siecią wewnętrzną a siecią zewnętrzną



Firewall – zadania

- Filtrowanie pakietów
- Proxy
- NAT
- VPN

Firewall – rodzaje

- Sprzętowy
- Programowy

Firewall

- Pracują w dowolnych warstwach modelu OSI
- Typu
  - Bezstanowe
  - Stanowe
- Rozwiązania sprzętowe (producenci)
  - Cisco
  - Checkpoint
  - PaloAltoNetworks
  - Watchguard

- Rozwiązania systemowe
  - IPFilter (Unix)
  - Ipfw (FreeBSD)
  - NPF (NetBSD)
  - PF (OpenBSD)
  - Iptables/ipchains (Linux)

Firewall bezstanowy (stateless)

- Pojawiły się w latach 80 XX wieku (routery)
- Pierwszy dokument – 1988 rok
- Filtrowały wyłącznie pakiety
- Jeśli dany pakiet spełnia którąś z reguł jest blokowany
  - Drop – zablokowanie
  - Reject – drop z informacją zwrotną
- Firewall tego typu nie sprawdza czy pakiet jest fragmentem już trwającej transmisji
- Wykorzystywane informacje
  - Docelowy i źródłowy adres
  - Protokół
  - Prot docelowy i źródłowy (w przypadku TCP i UDP)
- Zazwyczaj pracują w warstwie fizycznej, łącza danych i sieciowej
- Z warstwy transportowej pochodzi informacja dotycząca portu
- Zalety: szybki, małe wymagania sprzętowe
- Wady: brak definicji kierunku ruchu, brak śledzenia sesji, analiza nagłówków protokołu

Firewall stanowy (stateful)

- Przechowuje informację o zestawionych sesjach i połączeniach – stan łącza, sesja TCP
- Monitorowanie pakietów przychodzących i wychodzących
- Informacje przechowywane są w tablicy dynamicznej
- Decyzje podejmowane są nie tylko na podstawie reguł, ale również kontekstu
- Pakiety należące do sesji są przesyłane natychmiast
- Three-way handshake
- Pakiety z flagą SYN traktowane są jako próba nawiązania nowej sesji/połączenia
- Zalety: weryfikacja kierunku ruchu, śledzenie sesji, analiza kontekstowa nagłówków, dodatkowe funkcje np. proxy
- Wady: wolniejszy, większe wymagania sprzętowe

Firewall programowy

- Pracują w warstwie aplikacji
- Kontrolują informacje przychodzące i wychodzące oraz próby dostępu do aplikacji lub usługi
- Typy
  - Network-based
  - Host-based

Network-based

- Może działać np. na hoście przez który przechodzi cały ruch sieciowy
- Nadzoruje ruch, filtruje zawartość
- Tego typu firewall może zostać tak skonfigurowany aby kontrolował tylko konkretne usługi

Host-based

- Oprogramowanie zainstalowane na komputerze
- Badane są wywołania systemowe
- Chroni wyłącznie aplikacje zainstalowane na tym samym komputerze

- Mogą być blokowane reklamy
- Tryb interaktywnego uczenia się po instalacji
- Często ze zintegrowaną ochroną antywirusową

Proxy

- Pośredniczą w transmisji
- Użytkownik wysyła zapytanie do proxy
- Proxy przesyła zapytanie do odpowiedniego serwera
- Zastosowania:
  - Filtrowanie zawartości
  - Podmiana źródła transmisji
  - Analiza ruchu w sieci
  - Cache

Open Proxy

- Dostępne dla każdego
- Zapewniają anonimowość (zaleta dla użytkownika, wada dla administratora)
- Open proxy są często blokowane przez serwery
- Przykład
  - https://hidemyass.com/proxy-list/

Reverse proxy

- Zapytania pochodzą z Internetu
- Proxy kieruje zapytania do odpowiednich serwerów
- Serwery znajdują się w sieci wewnętrznej
- Zalety:
  - Ukrywanie informacji o serwerze, który udzielił odpowiedzi
  - Ochrona przed atakami
  - Równoważenie obciążenia
  - Cache
  - Redukcja adresów IP

NAT

- Zmieniany jest adres źródłowy w nagłówku IP
- Pozwala na ukrycie adresu źródłowego (sieć lokalna)
- Dynamicznie tworzona jest tablica translacji
- Statyczna tablica – port forwarding
- Typy:
  - 1 : 1
  - 1 : wielu
  - 1 : wielu z translacją portów

1 : 1

- Translacja 1:1 adresów prywatnych na publiczne (i na odwrót)
- Każdy adres prywatny musi mieć odpowiadający mu adres publiczny
- Ukrycie źródła
- Główna wada: liczba niezbędnych adresów publicznych

1 : wielu

- Zdefiniowana jest pewna pula adresów publicznych
- Translacja adresów odbywa się dynamicznie
- Router zapisuje informację o każdej translacji (odpowiedź)

1 : wielu z translacją portów

- Wystarczy jeden adres publiczny
- W nagłówku oprócz adresu źródłowego IP zmieniany jest również port źródłowy
- Tworzona jest tablica translacji (adres + port)
- Pozwala ograniczyć liczbę wykorzystywanych adresów publicznych

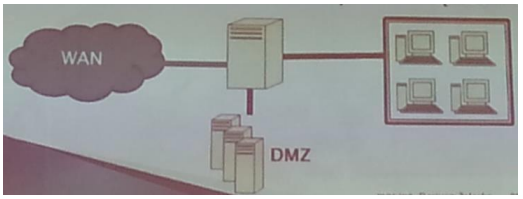
NAT a IPv6

- Na chwilę obecną nie ma konieczności stosowania
- Przypomnienie

IPv4	IPv6
2^{32}	d^{128}
$4.3*10^{9}$	$\sim 3.4*10^{38}$

DMZ

- Strefa zdemilitaryzowana
- Urządzenia znajdujące się w tej strefie są widoczne z sieci WAN
- Strefa ta jest odizolowana od sieci LAN
- W routerach SOHO urządzenie DMZ jest w tej samej sieci LAN co zwykłe urządzenie



iptables

- iptables od Linuxa 2.4, wcześniej ipchains
- Program do konfiguracji reguł firewalla
- Umożliwia tworzenie tabel zawierających łańcuchy reguł przetwarzania pakietów
- Tabele
  - Filter
  - Nat
- Reguły
  - PREROUTING (nat)
  - INPUT (filter)
  - FORWARD (filter)
  - OUTPUT (filter, nat)
  - POSTROUTING (nat)
- Akcje
  - ACCEPT
  - DROP
  - REJECT
- Firestarter – graficzna nakładka na iptables
- Następca iptables: nftables (kernel 3.13)
- Bazuje na wirtualnej maszynie

Darmowe Firewalle

- Endian firewall
- IPCop
- IPFire
- Vyatta

Konfiguracja firewall

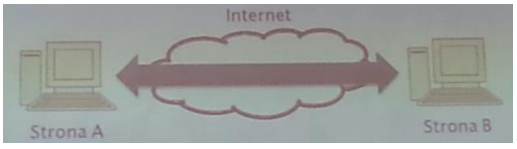
- Z routowaniem
- Drop-in
- Bridge

VPN

- Virtual Private Network
- Umożliwia transmisję danych poprzez sieć publiczną przy użyciu bezpiecznego kanału
- Zestawienie połączenia point-to-point
- Umożliwia udostępnienie zasobów z sieci prywatnej użytkownikowi znajdującemu się poza siecią prywatną
- Przykład: firmowe VPN
- Podział:
  - Remote-Access
  - Site-to-Site
- Typy
  - Host-to-host
  - Host-to-net
  - Net-to-net

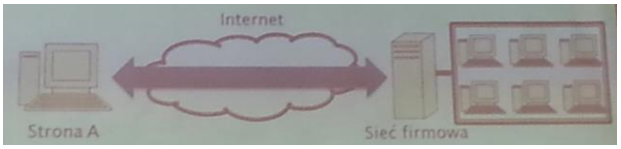
VPN – host-to-host

- Tunel zestawiany jest pomiędzy komputerami
- Strony muszą być wyposażone w odpowiednie oprogramowanie lub sprzęt
- Zadania oprogramowania/sprzętu – szyfrowanie i deszyfrowanie



VPN – host-to-net (remote-access)

- Jedną stronę stanowi komputer klienci, drugą odpowiednie urządzenie
- Strona kliencka uzyskuje dostęp do zasobów sieci korporacyjnej
- Komunikacja jest szyfrowana (całą lub usługi)



VPN – net-to-net (site-to-site)

- Obie strony stanowią dedykowane urządzenia sieciowe
- Mogą szyfrować całą transmisję ze swoich sieci lokalnych lub pewne wybrane usługi
- Szyfrowana jest wyłącznie transmisja między lokalizacjami

- Transmisja w obrębie sieci lokalnych nie jest szyfrowana



VPN – bezpieczeństwo

- Poufność
- Uwierzytelnianie
- Integralność
- Protokoły
  - IPSec
  - SSL/TLS
  - DTLS
  - SSTP

VPN – szyfrowanie

- Zazwyczaj wykorzystywane są następujące metody szyfrowania
  - PGP
  - IDEA

PGP

- Oparty na MD5, RSA i IDEA
- Autor: Philip Zimmermann
- Początkowo bezpłatny
- Od wersji 5.0 bezpłatny do zastosowań niekomercyjnych
- W 2010 firma PGP została przejęta przez Symantec

PGP algorytm – szyfrowanie

1. Generowany jest losowy klucz
2. Dane wejściowe są szyfrowane przy użyciu wygenerowanego klucza
3. Klucz szyfrowany jest przy użyciu klucza publicznego odbiorcy
4. Zaszyfrowane dane i klucz są przesyłane do odbiorcy

PGP algorytm – deszyfrowanie

1. Z zaszyfrowanej wiadomości wyodrębniane są zaszyfrowane dane i klucz
2. Klucz jest deszyfrowany przy użyciu klucza prywatnego odbiorcy
3. Dane deszyfrowane są przy użyciu odszyfrowanego klucza

VPN – tunelowanie

- VPN często opiera się na tunelowaniu
- Protokoły
  - Carrier Protocol
  - Tunneling Protocol
  - Passenger

VPN – uwierzytelnianie

- Strony muszą zostać uwierzytelnione
- Różne metody uwierzytelniania

IPSec

- Stworzony w celu zabezpieczenia protokołu IP
- Zbiór otwartych standardów
- Wykorzystywany w IPv4 i IPv6
- Dostarcza mechanizmy uwierzytelniania i szyfrowania
- Szyfrowanie i uwierzytelnianie odbywa się dla każdego pakietu
- Wykorzystywany przez VPN
- Wykorzystanie IPSec nie wymusza stosowania specjalnego sprzętu/oprogramowania
- IPSec może zabezpieczać dowolny protokół warstwy wyższej (np. TCP, UDP, ICMP)
- Dawniej tworzono dedykowane łącza punkt-punkt
- Nie gwarantuje identyfikacji nadawcy
- IPSec wykorzystuje
    - Algorytm Diffiego-Hellmana – do wymiany kluczy
    - PKI – do negocjacji klucza
    - DES – do szyfrowania danych
    - MD5 i SHA – do generowania skrótów
    - Certyfikatów cyfrowych
- Składa się z dwóch podstawowych komponentów
    - Danych dodawanych do pakietu IP zapewniających autentyczność, poufność i integralność – nagłówek AH lub ESP
    - IKE – mechanizm wymiany kluczy wykorzystywanych w trakcie negocjacji bezpiecznego połączenia

IPSec – security association

- Określa zależności bezpieczeństwa pomiędzy stronami
- Jest jednokierunkowym kanałem
- Jeśli komunikacja ma być dwukierunkowa muszą być dwa kanały
- Każdy kanał posiada swój własny SPI, licznik sekwencyjny i klucze kryptograficzne
- SA definiowana jest przez losowy SPI, docelowy adres IP oraz identyfikator protokołu zabezpieczeń (AH lub ESP)
- W momencie wysłania pakietu, który wymaga zabezpieczenia przez IPSec system sprawdza w bazie relacje zabezpieczeń i umieszcza SPI w nagłówku IPSec
- Parametry zabezpieczeń negocjowane są w trakcie zestawiania połączenia
- Obowiązują przez cały czas działania relacji

Protokół AH

- Zapewnia integralność i uwierzytelnianie
- Nie zapewnia poufności
- Protokół numer 51
- Tworzony jest skrót z pakietu (MD-5, SHA-1 lub inne w zależności od negocjacji)
- Niezaprzeczalność: np. RSA

<table>
<tr><td>0 7</td><td>8 15</td><td>16 23 24 31</td></tr>
<tr><td>Next header</td><td>Payload len</td><td>Reserved</td></tr>
<tr><td colspan="3">Security Parameters Index</td></tr>
<tr><td colspan="3">Sequence Number</td></tr>
<tr><td colspan="3">Integrity Check Value</td></tr>
</table>

…

- Next header – identyfikator protokołu
- Payload len – liczba 32 bitowych segmentów
- Reserved – pole wypełnione 0
- Security Parameters Index (SPI) – wynegocjowana liczba identyfikująca zabezpieczenie
- Sequence number – liczba, która zwiększa się dla każdego pakietu AH
- Integrity Check Value (ICV) – suma kontrolna

Protokół ESP

- Zapewnia szyfrowanie całego pakietu
- Podpisywanie pakietu – funkcje skrótu
- Szyfrowanie – szyfry blokowe w trybie CBC

<table>
<tr><td colspan="2">0 7</td><td colspan="2">8 15</td><td>16 23</td><td>24 31</td></tr>
<tr><td colspan="6">Security Parameters Index</td></tr>
<tr><td colspan="6">Sequence Number</td></tr>
<tr><td colspan="6">Payload data</td></tr>
<tr><td colspan="2"></td><td colspan="4">Padding (0-255B)</td></tr>
<tr><td colspan="3"></td><td colspan="2">Pad length</td><td>Next header</td></tr>
<tr><td colspan="6">Integrity Check Value
…</td></tr>
</table>

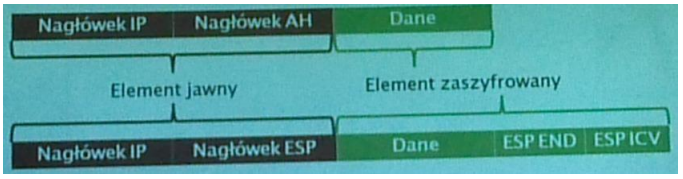
- Security Parameters Index (SPI) – wynegocjowana liczba identyfikująca zabezpieczenie
- Sequence number – liczba, która zwiększa się dla każdego pakietu ESP
- Payload data – pakiet danych protokołu zgodnego z polem next header
- Padding – wykorzystywane do zapewnienia odpowiedniego rozmiaru danych dla algorytmu szyfrującego (pole opcjonalne)
- Pad Length – rozmiar uzupełnienia w bajtach
- Next header – identyfikator protokołu
- Integrity Check Value (ICV) – suma kontrolna (pole opcjonalne)

IPSec

- Tryby pracy:
  - Transportowy
  - Tunelowania

IPSec – tryb transportowy

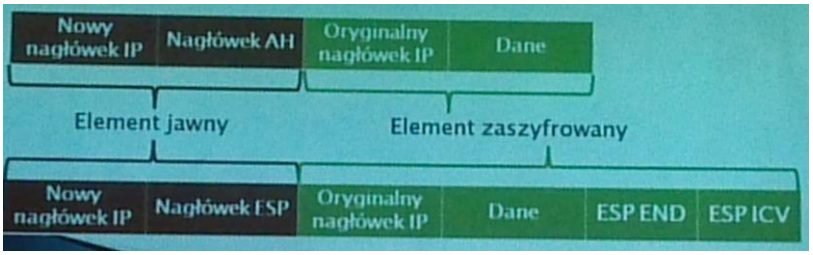
- Szyfrowana jest wyłącznie zawartość
- Nie zapewnia integralności danych
- Dodawany jest nagłówek AH/ESP
- Bezpieczne łącze między hostami



IPSec – tryb tunelowania

- Cały pakiet jest szyfrowany (nagłówek + dane)
- Następnie tworzony jest nowy pakiet z nowym nagłówkiem
- Wspiera NAT traversal

- Stosowany gdy chociaż jedna strona to brama
- Może być również stosowany do komunikacji host-host



NAT Traversal

- Gdy wykorzystywany jest IPSec wykorzystują NAT Traversal aby pakiety ESP przeszły przez NAT
- Umożliwia urządzeniom znajdującym się za NAT zestawienie bezpiecznego połączenia
- Najpierw następuje sprawdzenie czy na drodze pomiędzy źródłem a cele znajdują się urządzenia NAT
- W tym celu każda ze stron wysyła pakiet NAT-D zawierający skrót z IP i portu
- Urządzenie które odbierze pakiet NAT-D oblicza swój własny skrót i porównuje z tym otrzymanym
- Różne skróty oznaczają, że po drodze znajduje się urządzenie NAT
- Następnie wykorzystywany jest NAT-T
- Pakiety IPSec są enkapsulowane w datagramy UDP i przesyłane do urządzenia docelowego
- W Windows XP Nat Traversal domyślnie jest włączony
- Od Windows XP SP2 jest domyślnie wyłączony

IPSec – bazy danych

- Dwie bazy danych
  - SPD – Security Policy Database
  - SAD – Security Association Database

Baza SPD

- Baza SPD pozwala klasyfikować ruch sieciowy na:
  - Inbound
  - Outbound
  - To be protected
  - Not to protect
- Możliwe decyzje:
  - Reject
  - Nie stosuj IPSec
  - Zastosuj IPSec

Baza SAD

- Rekord w bazie SAD – aktywna relacja zabezpieczeń
- Indeksowanie – adres docelowy, typ protokołu IPSec, SPI
- Zawiera:
  - Licznik numeru sekwencyjnego
  - Wskaźnik przepełnienia licznika
  - Anit reply
  - Algorytm uwierzytelniania, klucza (dla AH)
  - Algorytm szyfrowania, klucze, algorytm uwierzytelniania (dla ESP)
  - Czas życia
  - Tryb pracy

IPSec – wysyłanie pakietu

1. Sprawdzenie konieczności zabezpieczenia i sposobu
    a. Sprawdzenie polityki w SPD – odrzucenie pakietu, przesłanie lub dalsze przetworzenie
2. Ustalenie Security Association
    a. Przeglądnięcie bazy SAD
    b. Nawiązanie SA
3. Zastosowanie zabezpieczeń
    a. Utworzenie nagłówka AH lub ESP
    b. W trybie tunelowym utworzenie nowego nagłówka IP
4. Wysłanie gotowego pakietu

IPSec – odebranie pakietu

1. Weryfikacja nagłówka IPSec
    a. Sprawdzana jest baza SAD w poszukiwaniu SA zgodnego z SPI nagłówka, dalsze przetwarzanie zgodnie z SA
    b. Odrzucenie gdy SA nie istnieje
2. Sprawdzenie konieczności zabezpieczenia i sposobu
    a. Sprawdzenie polityki w SPD – odrzucenie pakietu, dalsze przetworzenie

IPSec – zarządzanie kluczami

- Dystrybucja kluczy nie należy do specyfikacji IPSec
- Możliwe metody dystrybucji:
    - Ręczna
    - Automatyczna
        - Systemy dystrybucji
        - Integracja z usługami katalogowymi
        - Niezależne od IPSec protokoły i serwery

IKE

- Internet Key Exchange
- Zaprojektowany przez NSA
- Służy do wymiany kluczy oraz zestawiania bezpiecznych połączeń
- Składa się z dwóch części
    - ISAKMP – specyfikacja formatu pakietów i stanów
    - Oakley – kryptograficzne metody uwierzytelniania i negocjacji kluczy
- W przypadku IPSec
    - ISAKMP – negocjacja parametrów IPSec
    - Oakley – wymiana kluczy przy użyciu algorytmu Diffiego-Hellmana
- ISAKMP umożliwia definiowanie własnych parametrów (DOI) – zestaw szyfrów i mechanizmy uwierzytelniania

IKE – zasada działania

1. Uwierzytelnienie stron
2. Zestawienie bezpiecznego kanału ISAKMP SA
3. Uzgodnieni kluczy i parametrów IPSec
4. Renegocjacja co określony czas

Uwierzytelnianie (Kerberos)

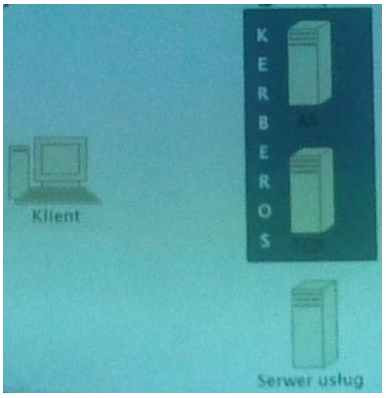
- Składniki systemu
    - Klient – źródło identyfikatora i hasła

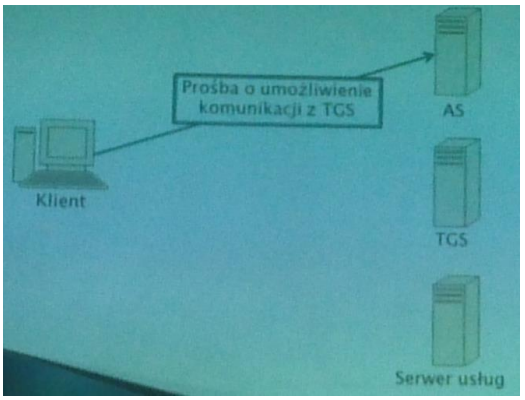
- Authentication server – przechowuje hasła i weryfikuje tożsamość użytkownika, THT
- Ticket-granting server – dostarcza klientowi bilet umożliwiający wykorzystanie usługi dostępnej na serwerze usług
- Serwer usług – świadczy pewną usługę, chce mieć pewność co do tożsamości klienta

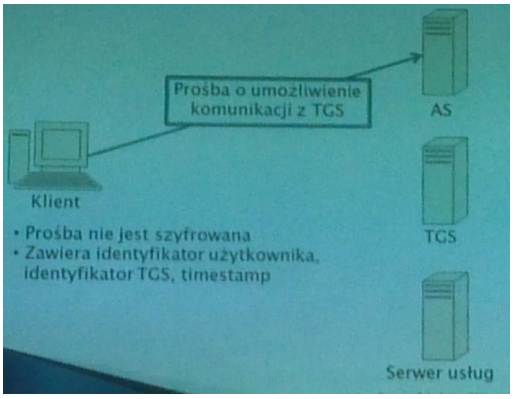
Kerberos

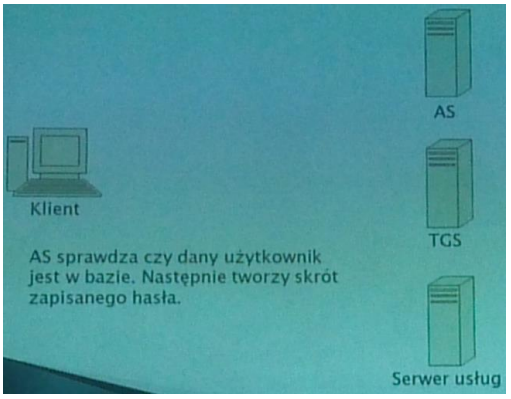
- Protokół uwierzytelniania i autoryzacji
- Powstał na uniwersytecie MIT w ramach projektu Athena
- Wykorzystuje port 88 UDP
- Jest bazą danych zawierającą dane dotyczące tożsamości oraz hasła
- Ze względu na rodzaj przechowywanych danych trzeba zapewnić odpowiedni poziom bezpieczeństwa
- Służy do wydawania biletów będących przepustkami do usług

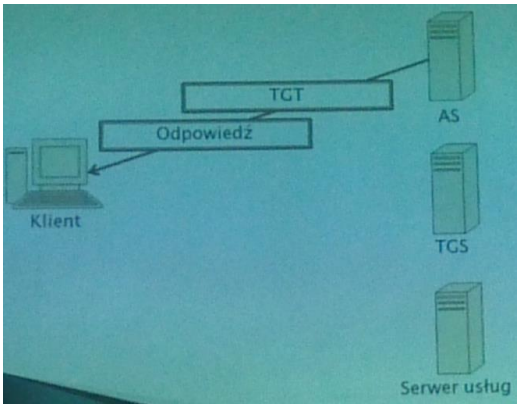
Uwierzytelnianie – algorytm

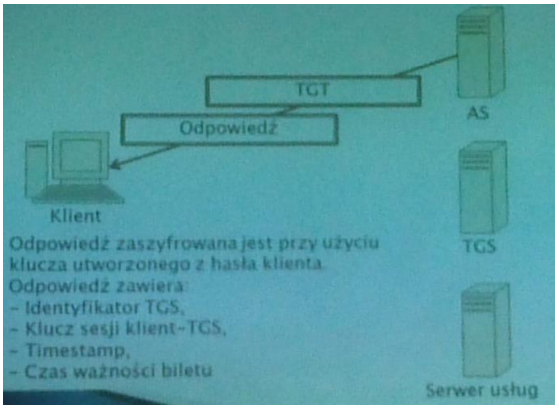


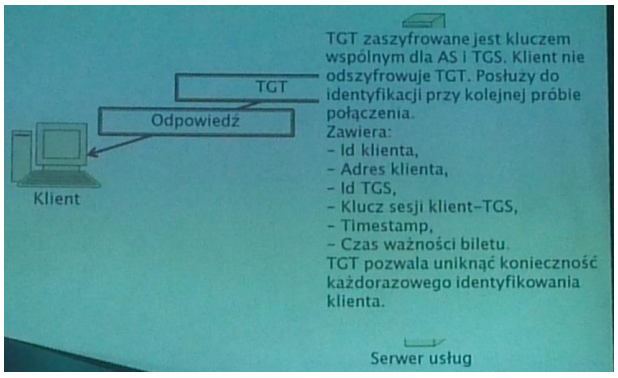


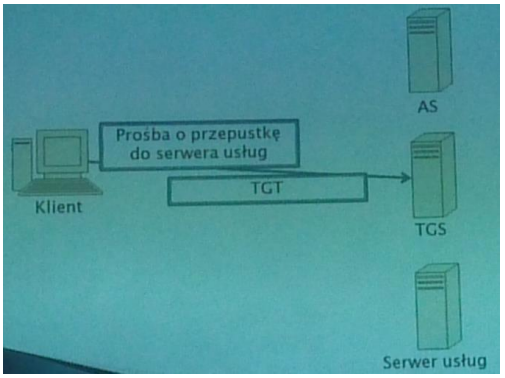


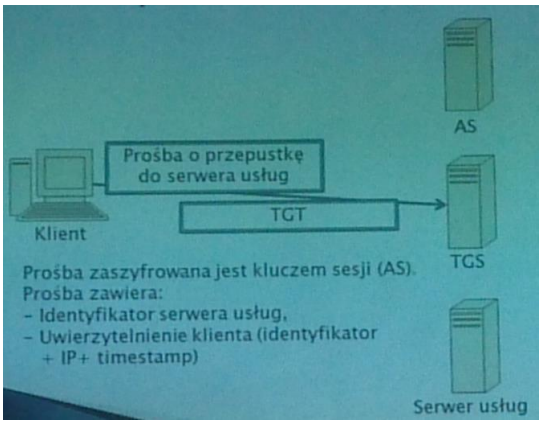


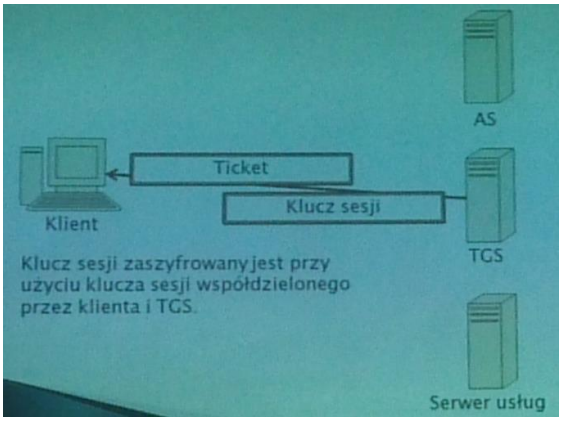


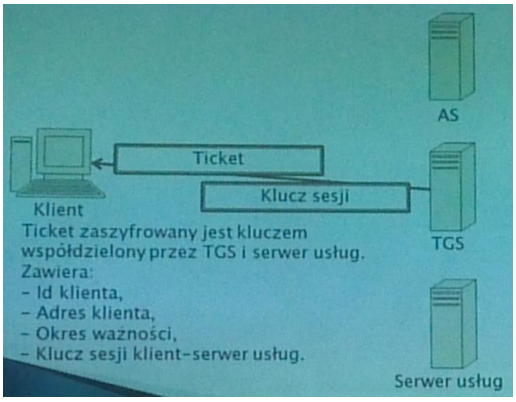


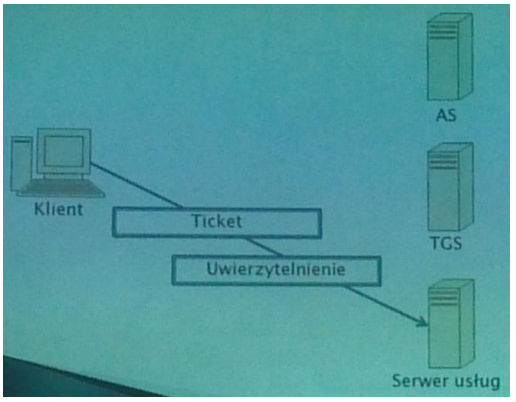

TGT
Odpowiedź
Klient
TGT zaszyfrowane jest kluczem wspólnym dla AS i TGS. Klient nie odszyfrowuje TGT. Posłuży do identyfikacji przy kolejnej próbie połączenia.
Zawiera:
- Id klienta,
- Adres klienta,
- Id TGS,
- Klucz sesji klient-TGS,
- Timestamp,
- Czas ważności biletu.
TGT pozwala uniknąć konieczność każdorazowego identyfikowania klienta.
Serwer usług

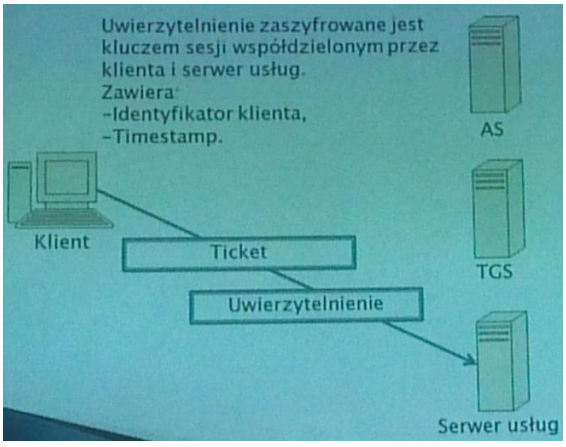

AS
Prośba o przepustkę do serwera usług
TGT
Klient
TGS
Serwer usług

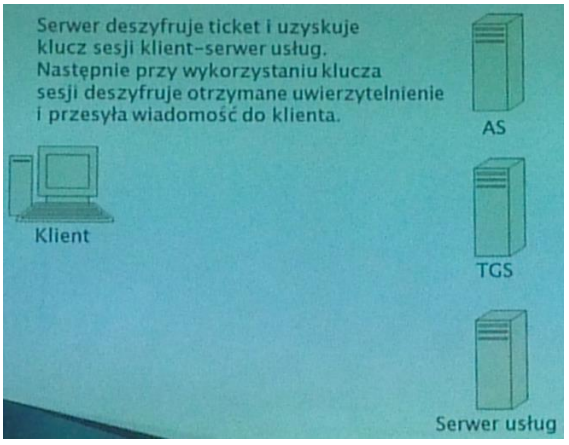

AS
Prośba o przepustkę do serwera usług
TGT
Klient
TGS
Prośba zaszyfrowana jest kluczem sesji (AS).
Prośba zawiera:
- Identyfikator serwera usług,
- Uwierzytelnienie klienta (identyfikator + IP+ timestamp)
Serwer usług

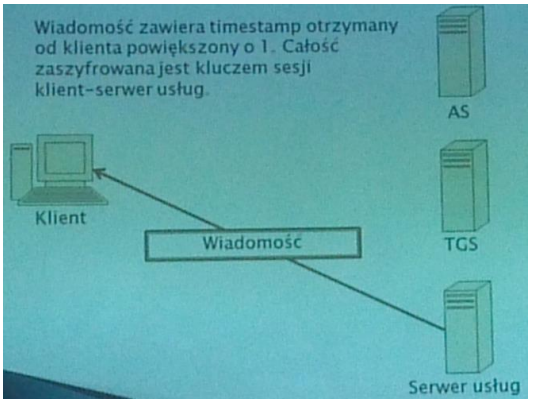

AS
Ticket
Klucz sesji
Klient
TGS
Klucz sesji zaszyfrowany jest przy użyciu klucza sesji współdzielonego przez klienta i TGS.
Serwer usług

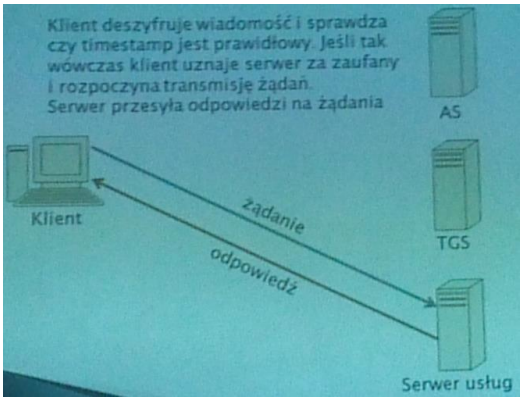

AS
Ticket
Klucz sesji
Klient
TGS
Ticket zaszyfrowany jest kluczem współdzielony przez TGS i serwer usług.
Zawiera:
- Id klienta,
- Adres klienta,
- Okres ważności,
- Klucz sesji klient-serwer usług.
Serwer usług


AS
Klient
Ticket
TGS
Uwierzytelnienie
Serwer usług


Uwierzytelnienie zaszyfrowane jest kluczem sesji współdzielonym przez klienta i serwer usług.
Zawiera:
-Identyfikator klienta,
-Timestamp.
AS
Klient
Ticket
TGS
Uwierzytelnienie
Serwer usług


Serwer deszyfruje ticket i uzyskuje klucz sesji klient-serwer usług.
Następnie przy wykorzystaniu klucza sesji deszyfruje otrzymane uwierzytelnienie i przesyła wiadomość do klienta.
AS
Klient
TGS
Serwer usług


Wiadomość zawiera timestamp otrzymany od klienta powiększony o 1. Całość zaszyfrowana jest kluczem sesji klient-serwer usług.
AS
TGS
Klient
Wiadomość
Serwer usług


Klient deszyfruje wiadomość i sprawdza czy timestamp jest prawidłowy. Jeśli tak wówczas klient uznaje serwer za zaufany i rozpoczyna transmisję żądań.
Serwer przesyła odpowiedzi na żądania
AS
TGS
Klient
żądanie
odpowiedź
Serwer usług